



Stop Changing Your Passwords!

Practical Security That *Actually* Works

Presented by Garrett Miller, RipRap Security



WHY DID WE GET STARTED?

To Simplify Cyber Security for Non-Profits and B-Corps

- ➔ Founded with the goal of **empowering organizations** that **create positive change** in the world.
- ➔ We believe in **human-first cyber security**—building trust, educating, and creating long-term partnerships with our clients.



**National
Security
Agency**



**Central
Intelligence
Agency**



Founders Garrett Miller (left) and Steve Sharer

BONA FIDES

Credentials You Can Trust

We have deep cyber security expertise with a focus on protecting organizations with a purpose.



B Corp Initiatives

We're a proud certified B Corp, committed to using business as a force for good.

1% for the Planet

We actively contribute 1% of revenue to environmental partners through our 1% for the Planet Partnership.

Carbon Neutral

We offset our carbon footprint, ensuring our operations contribute to a healthier planet.

A Quick Note On Copy Fail (CVE-2026-31431)

Copy Fail (CVE-2026-31431), is a local privilege escalation vulnerability affecting nearly all Linux operating systems released since 2017.

This means that while it doesn't grant remote access to a Linux system directly, it significantly increases the damage an attacker can do if they have an unprivileged account on the system, or exploit an application hosted on that system.

Affects traditional Linux operating systems as well as Linux container environments.



Some Common Security Advice is Outdated

A nonprofit staffer is dutifully rotating their password every 90 days, clicking through their annual security training, connecting to the VPN...
...and still getting breached.

- ➡ Compliance-driven “feel good” security vs. *actual* security
- ➡ Let’s retire some **security zombies** – outdated practices that just won’t go away



The Old Playbook Made Sense – It Doesn't Anymore

The 2010's Model

- ➔ Perimeter defense
- ➔ On-premises systems
- ➔ External attackers

Today's Model

- ➔ Identity-based attacks
- ➔ Insider risk
- ➔ Cloud-first infrastructure
- ➔ AI-assisted phishing

90%+ of breaches now start with compromised credentials or phishing, not network intrusion.

The threats have evolved, our defenses need to evolve too.



Zombie #1: Password Rotation

“Change your password every 90 days” is making you less secure

Why it Made Sense in the Past

Limited breach detection, slower attacks,
simpler systems

What *Actually* Happens

Summer2025! → Fall2025! → Winter2026!

**Rotation doesn't stop any of the real threats – credential stuffing,
password reuse, and phishing.**



Modern Password Security

What Works Instead



Length Beats Complexity: 14+ characters, never reused, randomly generated. A short sentence of 4–5 words (spaces are fine) is an easy way to get sufficient length (e.g. “I like blueberry muffins!”)



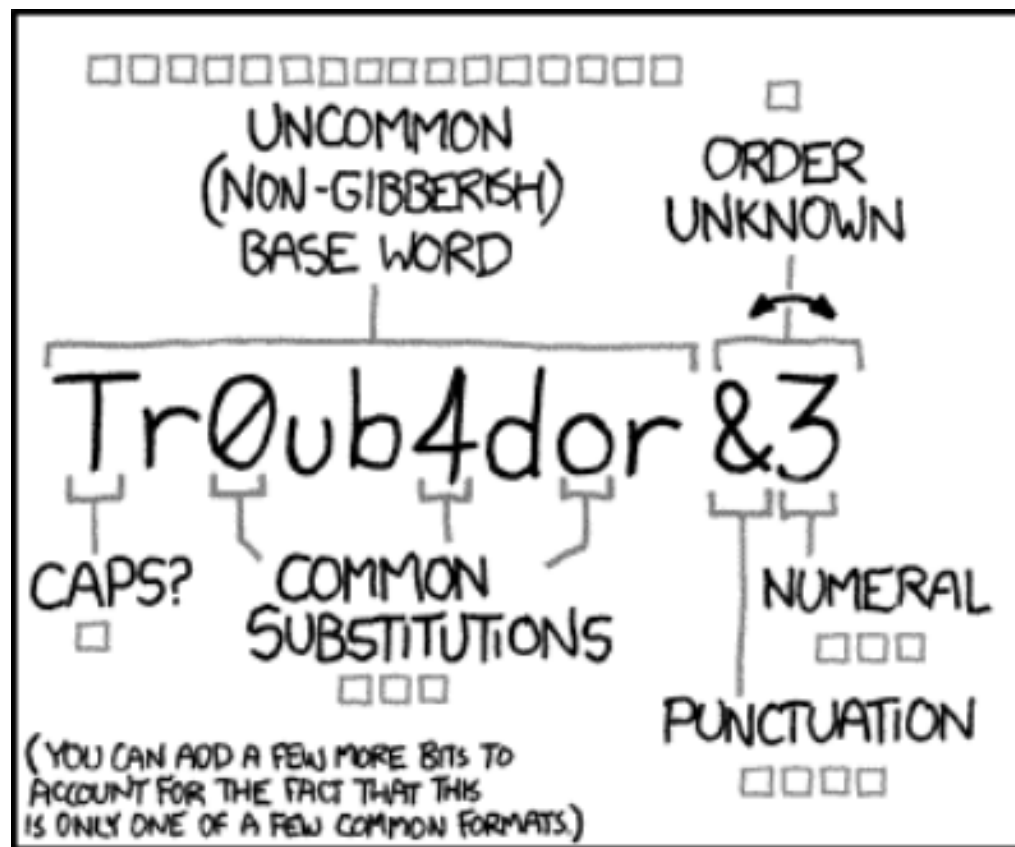
Password Managers: Organizationally-deployed password managers (like 1Password) that generate strong passwords, store them in an encrypted vault, and fill them in only on legitimate sites, giving extra protection against phishing



Breached Credential Monitoring: Automated alerts when your credentials appear in known breaches. Change the password when there's a reason to, not on an arbitrary schedule.



The Real Force Multiplier: MFA everywhere, especially phishing-resistant options like passkeys and hardware security keys. Passkeys replace passwords with strong encryption. Even if attackers steal a password, they can't log in.



~28 BITS OF ENTROPY

□□□□□□□□
□□□□□□□□ □
□□□ □□□
□□□□ □

$2^{28} = 3 \text{ DAYS AT } 1000 \text{ GUESSES/SEC}$

(PLAUSIBLE ATTACK ON A WEAK REMOTE
WEB SERVICE. YES, CRACKING A STOLEN
HASH IS FASTER, BUT IT'S NOT WHAT THE
AVERAGE USER SHOULD WORRY ABOUT.)

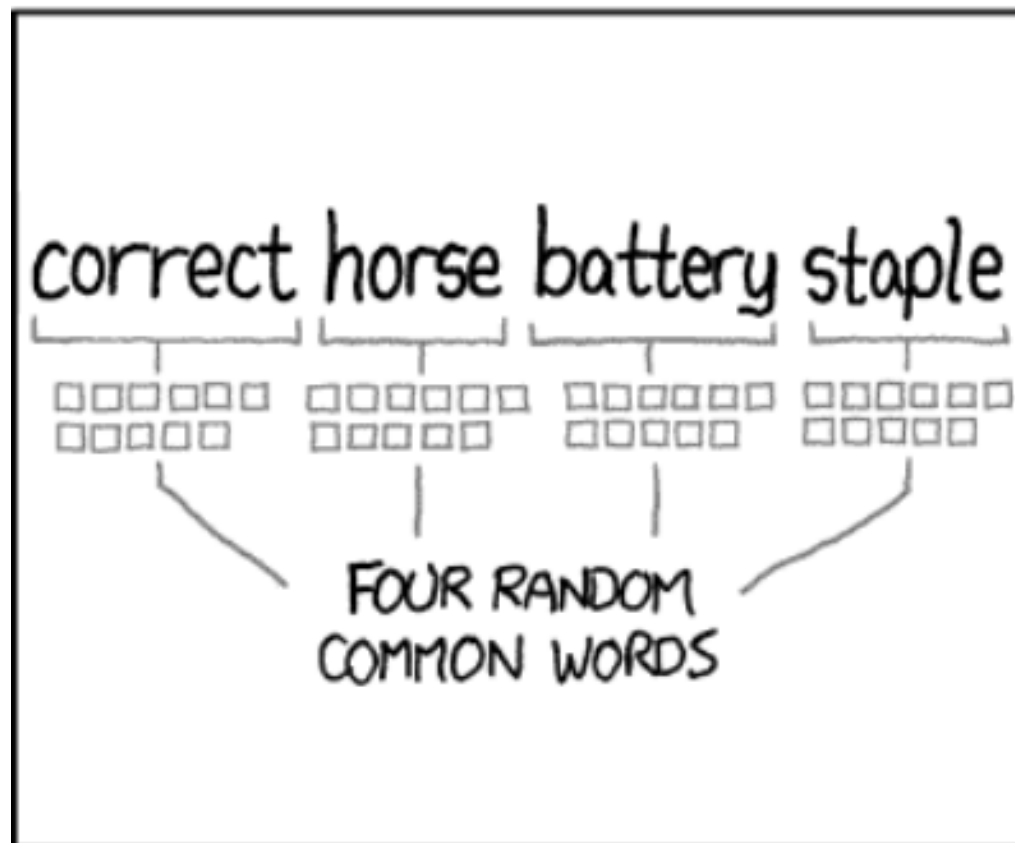
DIFFICULTY TO GUESS:
EASY

WAS IT TROMBONE? NO,
TROUBADOR. AND ONE OF
THE 0s WAS A ZERO?

AND THERE WAS
SOME SYMBOL...



DIFFICULTY TO REMEMBER:
HARD



~44 BITS OF ENTROPY

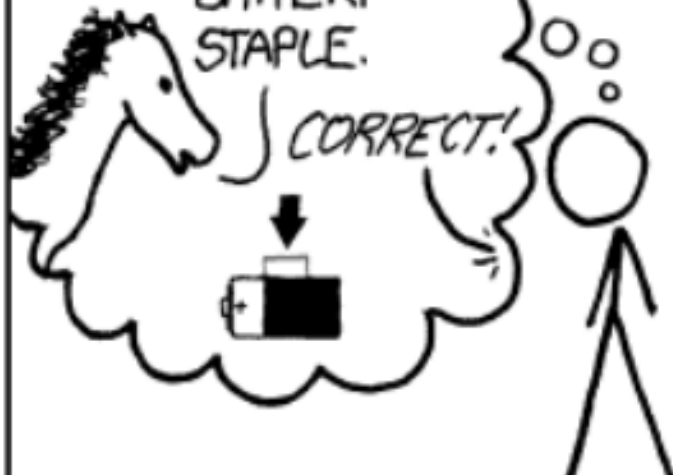
□□□□□□□□□□
□□□□□□□□□□
□□□□□□□□□□
□□□□□□□□□□

$2^{44} = 550 \text{ YEARS AT } 1000 \text{ GUESSES/SEC}$

DIFFICULTY TO GUESS:
HARD

THAT'S A
BATTERY
STAPLE.

CORRECT!



DIFFICULTY TO REMEMBER:
YOU'VE ALREADY
MEMORIZED IT

THROUGH 20 YEARS OF EFFORT, WE'VE SUCCESSFULLY TRAINED
EVERYONE TO USE PASSWORDS THAT ARE HARD FOR HUMANS
TO REMEMBER, BUT EASY FOR COMPUTERS TO GUESS.



Zombie #2: Your VPN Could Be Putting You at Risk

"Always Use the VPN" is expanding your attack surface

Why it Made Sense in the Past

The VPN was designed for a world where your data lived in one building, encryption was harder to do, and network-based attacks were more commonplace

What *Actually* Happens

The castle-and-moat problem: once someone is inside the VPN, they can move laterally across your entire network

All commercial VPNs do is *shift your trust point* from one location to another.



Identity is the New Perimeter

What Works Instead



Zero Trust Access: Verify every user and device for every session, every time



Conditional Access Policies (Entra ID / Okta): Grant access based on who you are, what device you're on, where you are, and what you're trying to reach



Identity-Centric Security: Trust the identity, not the network connection



Practical First Step for Nonprofits: Entra ID + MFA + device compliance is stronger, cheaper, and simpler than a legacy VPN



Zombie #3: Security Awareness Training

“Just Don’t Click on Phishing Emails” is not a security strategy

The Assumption

If you train people enough, they’ll stop clicking

What *Actually* Happens

Even trained users get phished, especially when under stress or in a hurry. Annual click-through training doesn’t change behavior in the moment of decision

The human should not be your last line of defense.

Protect People from Mistakes, Don't Blame Them

What Works Instead



Technical Controls with No Choice:

Link scanning, attachment sandboxing, anti-spoofing (SPF/DKIM/DMARC)



Phishing-Resistant MFA: Passkeys or hardware keys, so a click doesn't become a breach



Slow and Steady: Short, contextual security nudges over annual compliance marathons



Shared Reporting Channels: E.g., dedicated Slack channel for "I think this is phishing" to benefit the whole org



Normalize Reporting: Make it easy and safe to say "I think I messed up" and get help quickly



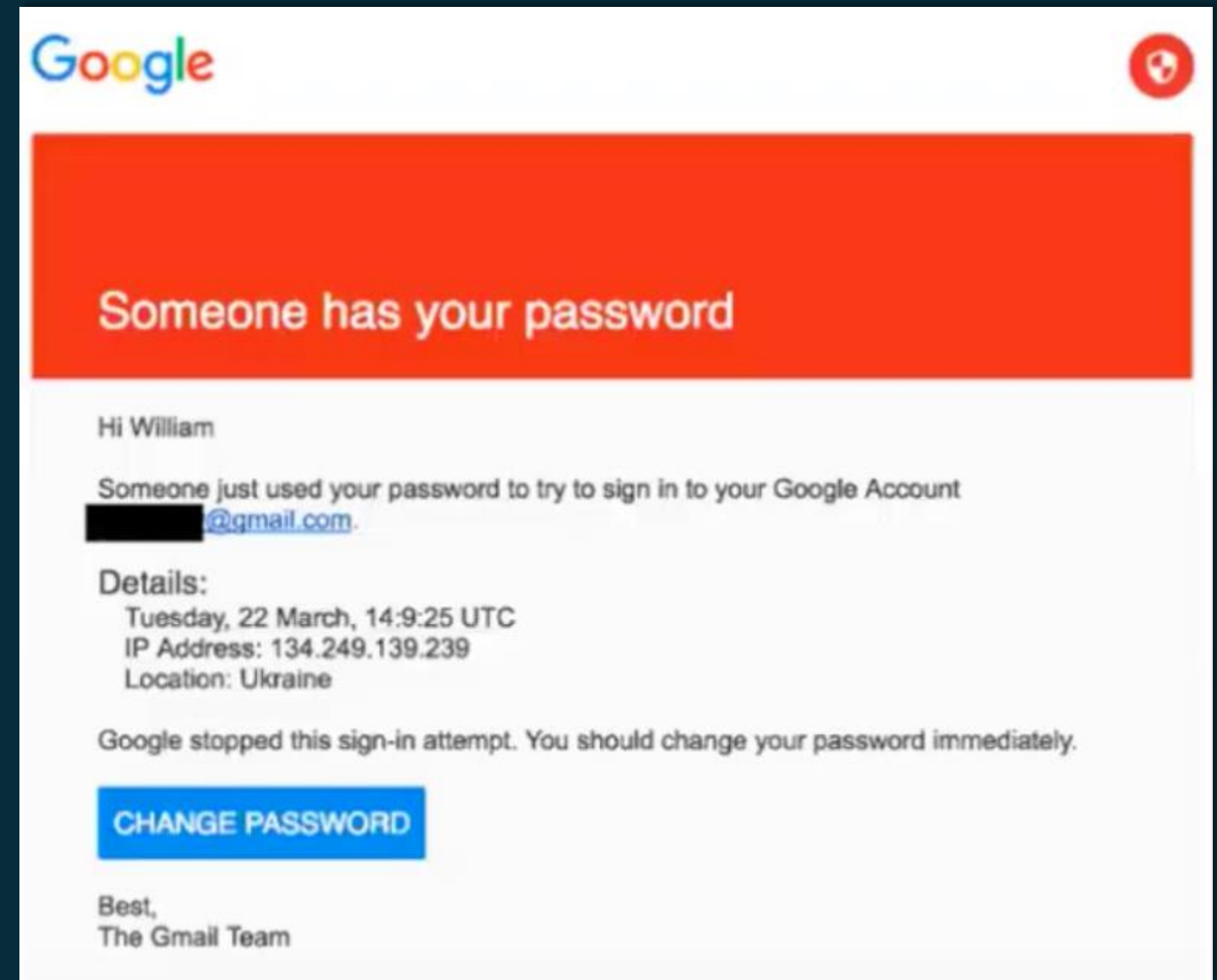
For Leaders: If an employee's mistake causes significant harm, the system was brittle. Fix the system, not the person.



Phishing-Resistant MFA

Think about this scenario:

- ➡ Someone has your password
- ➡ Phishing-resistant MFA (passkeys, hardware keys) makes it literally **impossible** for you to let this person in
- ➡ **The most meaningful security action you can take right now**





RAPID FIRE ROUND: **Everyday Security Myths**

Everyday Security Myths

Well-intentioned advice that wastes time

MYTH:

You should avoid public WiFi

REALITY:

Significant compromises via public WiFi are exceedingly rare today.

MYTH:

You should never scan QR codes

REALITY:

There is no evidence of widespread crime or risks originating from QR-code scanning itself, at least not significantly more than any regular link – use the same amount of caution.

MYTH:

You should never charge devices from public USB ports

REALITY:

There are no verified cases of “juice jacking” in the wild affecting everyday users.



More Security Myths

Stop spending time on these

MYTH:

You should turn off Bluetooth and NFC

REALITY:

Wireless exploits in the wild are extraordinarily rare and typically require specialized hardware, physical proximity, and unpatched devices.

MYTH:

You should regularly clear your cookies

REALITY:

Clearing cookies doesn't meaningfully improve security or stop modern tracking, which now uses identifiers and fingerprinting techniques beyond cookies.

Important Note: Some of these precautions may be warranted for organizations working with exceptionally sensitive populations, facing nation-state-level threats, or doing high-risk advocacy work.

Where to Focus Instead

- **Update what matters:** Keep critical devices and applications updated. Focus on the devices and apps you use for email, financial accounts, cloud storage, and identity. Enable automatic updates. When a device is no longer supported with security updates, consider replacing it.
- **MFA on every account:** Prioritize sensitive accounts (e.g., email, file storage, social media, financial systems). Use passkeys where possible. Use SMS codes only as a last resort.
- **Strong passphrases:** 14+ characters, unique, randomly generated. A short sentence of 4–5 words works great.
- **Password managers:** Generates strong passwords, stores them in an encrypted vault, fills them in on legitimate sites, and gives you extra phishing protection.
- **For system administrators:** Require phishing-resistant MFA wherever possible.

The Modern Playbook

IDENTITY



Identity is the New Perimeter

MFA everywhere, phishing-resistant where possible, plus Conditional Access policies

DEVICES



Know Your Devices

MDM and EDR on every endpoint – no device trust means no access

RESPONSE



Assume Breach, Detect Fast

SIEM/ITDR – the goal is reducing dwell time, not just prevention

The nonprofit reality: Even with limited budgets & small IT teams, modern security can be cheaper than legacy security if you prioritize right

Start with One Thing Today

- ➔ The mission is the point
- ➔ A breach doesn't just cost money. It costs trust and impact.
- ➔ For nonprofits, security protects the people you serve

Your Challenge:
Pick one zombie to retire
in the next 90 days



Where To Go From Here

Relevant Resources

- ➔ [The Hacklore Letter](#) open letter on retiring outdated security advice
- ➔ [NIST SP 800-63B-4](#) (2024 password guidance, §5.1.1.2)
- ➔ [Have I Been Pwned](#) breached credential check
- ➔ [CISA cybersecurity resources for small organizations](#)
- ➔ [CIS Controls](#) prioritized security benchmarks, free download

More From RipRap

- ➔ [Sign up for our newsletter](#) for actionable tips, real nonprofit security stories, and zero spam
- ➔ [Book a free consultation](#) to get personalized guidance on protecting your organization
- ➔ [Sign up for our Office Hours](#) sessions
- ➔ [Join our hacker-led Cyber Security Foundations course](#) (next cohort in September)



RIPRAP SECURITY

Thank You



garrett@riprapsecurity.com

